SAWM & BASIRA

DOSSIER CLIENT / OCTOBRE 2026



Cyberdéfense agentique

Observer. Comprendre. Intervenir. Prouver.

Une défense qui relie les événements du serveur, les décisions autorisées et leurs effets vérifiés.

VM Linux réelle - données fictives - API publiques
Résultats et périmètre arrêtés au 26 octobre 2026

Ce que le client peut déjà examiner

Disponibilité retrouvée - Un verrou SQLite non autorisé a conduit SAWM à choisir l'arrêt ciblé ; le service a retrouvé ses lectures et écritures.

Maintenance préservée - Un mandat signé protège les opérations autorisées. La garde locale bloque une tentative d'arrêt incompatible.

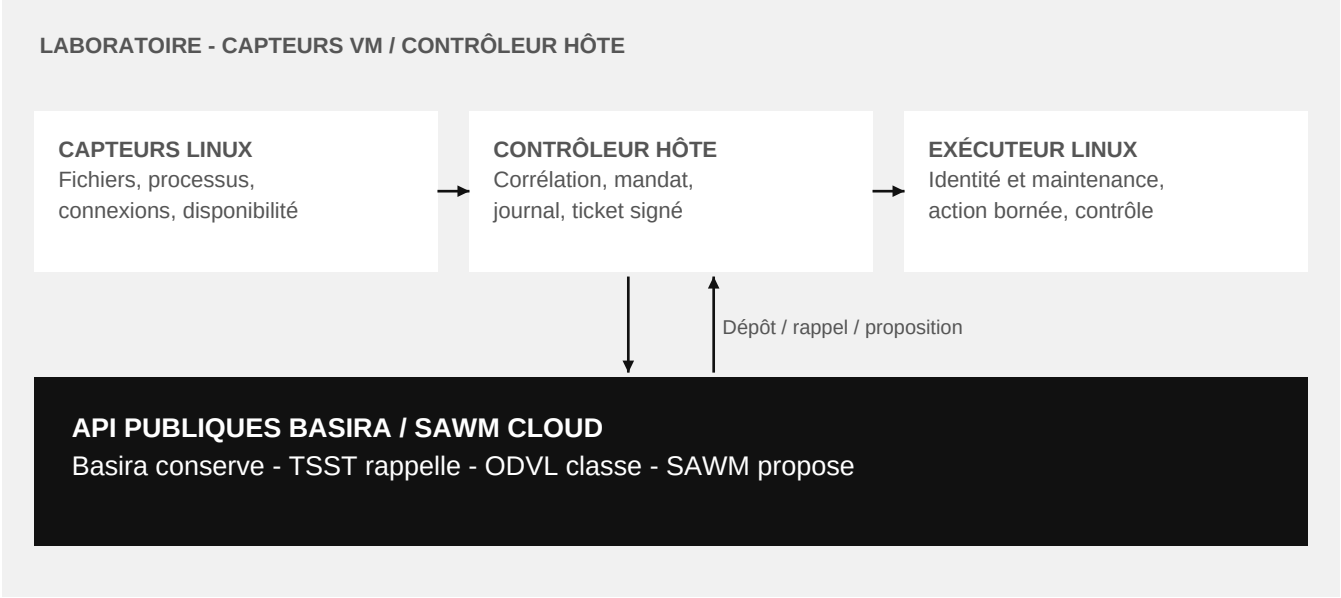
Actions explicables - Le dossier conserve faits, proposition, autorisation, reçu et effet. L'arrêt de l'auteur ne devient pas une restauration de données.

À lire : fonctionnement p. 2 - capacités p. 3 - défense en profondeur p. 4 - preuves p. 5 - audit p. 6 - ISO/CIS p. 7 - D3FEND p. 8 - intégration p. 9 - pilote et sources p. 10.

01 / FONCTIONNEMENT

Une boucle qui va jusqu’au résultat.

L’agent suit une situation, rappelle le contexte utile et choisit parmi les inspections et interventions déléguées. Le serveur vérifie les droits au moment d’agir.



Composant	Rôle concret
Basira	Conserve les observations et retours avec leur provenance, pour retrouver ce qui a été déclaré et ce qui a changé.
TSST	Rappelle les preuves pertinentes dans le périmètre autorisé. Le rappel ne remplace pas une mesure actuelle du serveur.
ODVL	Reclasse les candidats du rappel. Il n’ajoute ni droit ni preuve et ne certifie pas qu’une information est vraie.
SAWM	Examine le contexte, choisit une inspection ou une proposition et fournit une justification publique avec ses inconnues.

Le noyau observe et applique les protections prévues.

Dans cette campagne, les capteurs et l’exécuteur tournent dans la VM ; le contrôleur et le dashboard sur l’hôte. Les sondes eBPF et BPF LSM sont côté Linux. SAWM, Basira, TSST et ODVL restent des services consommés par API, hors du noyau.

Sources : R1 - Kit public et documentation ; R3 - Défense en profondeur et garde locale

02 / CAPACITÉS

Ce que l’équipe peut mettre à l’épreuve.

Une vue utile au responsable de sécurité : ce qui est observé, la réponse possible et la portée de la preuve disponible.

Situation	Réponse du système	État de preuve
Base bloquée	Attribuer le verrou, contrôler la maintenance, arrêter l’unité déléguée, retester la disponibilité.	**VM + SAWM** Validé le 26/10.
Fichier ou base altéré	Corréler empreinte et opération attribuée ; contenir l’auteur autorisé à être arrêté.	**VM locale** Confinement validé ; restauration distincte.
Maintenance planifiée	Vérifier signature, opération, cible, période et incarnation du processus ; opposer le veto.	**VM locale** Protection validée.
Connexion forcée	Compter les refus, exclure temporairement une source sur le service d’essai, vérifier le retour.	**VM locale** Port fictif 8082 ; pas un pare-feu global.
Connexion SSH rejetée	Observer les refus et alerter en gardant l’accès légitime.	**VM + OpenSSH** Pas de bannissement SSH automatique.
Accès à une fixture protégée	Appliquer une politique BPF LSM et vérifier un accès témoin autorisé.	**VM + noyau** Lecture refusée, y compris au processus root testé.
CPU / réseau inhabituels	Inspecter processus, compte, connexions ou base ; proposer gel, arrêt ou limite CPU.	**Code + essais antérieurs** Qualification par cible requise.
Paquet ou grand dossier	Examiner un .deb soumis avec ClamAV ; inventorier et comparer des fichiers par blocs.	**Modules + tests** Pas revalidés en VM dans cette campagne.

Lecture des statuts. « VM » désigne un essai réel dans le laboratoire, sur données fictives. « Code + tests » signifie que la capacité existe, sans prétendre qu’elle a été éprouvée ici contre toutes les attaques. Un pic CPU ou une empreinte modifiée ne suffit pas à identifier un malware.

Sources : R2 - Essais VM du 26 octobre 2026 ; R3 - Défense en profondeur et garde locale

03 / DÉFENSE EN PROFONDEUR

Plusieurs contrôles. Une autorité explicite.

L’autonomie commence avec un mandat approuvé. Aucune phrase de l’agent ne peut élargir ses droits ni remplacer une preuve technique manquante.

1. **Mandat institutionnel**
   Unités et actions autorisées, services protégés, génération du manifeste et clés enrôlées.
2. **Observation datée**
   Faits système, attribution, posture et fraîcheur. Une mesure ancienne reste ancienne.
3. **Enquête bornée**
   Le modèle choisit parmi quatre inspections permises ; au plus trois inspections sous 120 secondes.
4. **Veto du contrôleur**
   Délégation, journal signé, capteurs, budget et contrôles bloquants choisis par l’administrateur.
5. **Ticket Ed25519**
   Autorisation liée à la décision, à l’action, à la cible, à son identité et à l’empreinte du manifeste.
6. **Réinspection locale**
   Maintenance, identité, mandat et ticket recontrôlés après écriture durable, avant mutation.
7. **Effet et preuve**
   Reçu, vérification de l’effet et du témoin ; dépôt du retour en mémoire et traçabilité.

Posture de la VM : 22 contrôles, dont 12 sondes OS



17 satisfaits / 3 écarts / 2 inconnus. Instantané de déploiement ; aucun taux de conformité ISO. Les écarts concernent SSH et NTP ; les inconnus, l’ancrage externe et l’attestation LSM continue.

Tickets : 5 s. Posture : validité maximale 60 s. La garde locale exige des preuves fraîches de 1 500 ms et revérifie avant l’action. Ces durées sont des critères d’autorisation, pas des délais garantis de détection.

Sources : R3 - Défense en profondeur et garde locale

04 / PREUVES AU 26 OCTOBRE

Une décision SAWM exécutée et vérifiée.

La campagne utilise de vrais processus Linux, de vraies bases SQLite et le Cloud réel. Les données de test sont fictives et le nettoyage opérateur est comptabilisé séparément.

Cas validé : remettre une base à disposition.

Le noyau attribue un verrou exclusif ; lectures et écritures sont bloquées. SAWM choisit **arreter-service**. Le ticket et les contrôles locaux autorisent l'intervention. La base redevient accessible, le témoin reste sain et le résultat est enregistré dans Basira.

Scénario	Décideur / mécanisme	Résultat observé
Verrou SQLite non autorisé	SAWM Cloud + exécuteur local	**Réussi.** Choix d'arrêt, effet vérifié et retour mémoire.
Verrou SQLite sans Cloud	Garde locale signée	**Réussi.** Arrêt ciblé, lectures et écritures rétablies.
Altération de base fictive	Garde locale signée	**Réussi.** Auteur confiné ; l'écart d'intégrité reste visible.
Maintenance avec mandat signé	Garde + exécuteur locaux	**Réussi.** Processus préservé ; tentative d'arrêt refusée.
Maintenance examinée par SAWM	SAWM Cloud	**Autonomie incomplète.** Aucun arrêt, mais clarification demandée au lieu du choix final attendu.
Autorisation absente, falsifiée ou expirée	Exécuteur local	**Refus vérifiés.** La cible n'est pas arrêtée par une demande non autorisée.

Répétition et contrôle. Les trois cas de garde locale ont été exécutés deux fois, dont une fois après le correctif de maintenance. Le mandat initial est restauré à l'identique après chaque scénario. L'altération n'a pas été revalidée par SAWM après la reprise du Cloud.

Validation logicielle distincte : 775 tests du runner isolé réussis, sources inchangées pendant l'exécution, puis 10 tests d'instances parallèles réussis. Aucun pourcentage de détection générale n'est extrapolé.

Sources : R2 - Essais VM du 26 octobre 2026

05 / TRAÇABILITÉ ET RÉSILIENCE

Expliquer l’action. Conserver l’écart.

Le dashboard donne une lecture commune aux exploitants, aux responsables de sécurité et aux auditeurs. Les preuves de campagne sont distinguées de la santé actuelle du serveur.

Question de l’auditeur	Ce que le dossier doit montrer
Que s’est-il passé ?	Source, date, observation, fichier ou unité concernée, attribution disponible et limites.
Pourquoi intervenir ?	Proposition structurée, justification publique, preuves retenues et inconnues. Les pensées internes du LLM ne sont pas une preuve.
Qui l’a autorisé ?	Mandat applicable, rôle du signataire, cible, action, durée du ticket et éventuelle maintenance.
L’action a-t-elle eu lieu ?	Reçu local, identité recontrôlée, effet observé et disponibilité du service légitime.
Le système a-t-il appris de ce retour ?	Dépôt du résultat dans Basira pour le rappel suivant. Cela ne prouve pas un entraînement automatique des poids du modèle.

Trois vues qui ne doivent pas se confondre

État courant : fraîcheur des capteurs, disponibilité, activité de la veille et contrôles de posture. Une donnée périmée ou absente devient explicitement inconnue.

Campagne récente : garde locale et pipeline SAWM séparés ; essais réussis, bloqués et échoués conservés ; cartes repliables, reçus et nettoyage distincts.

Historique : décisions, résultats, changements, signatures et références des rapports. Les archives ne valent pas état actuel du serveur.

Continuité locale et reprise maîtrisée

Les gardes locales supervisées peuvent agir sans Cloud dans leur mandat. La panne Cloud bloque les nouvelles décisions distantes. La campagne a rencontré une saturation mémoire et un worker arrêté ; la reprise a permis le tour SAWM validé. Le limiteur Cloud a été corrigé et redéployé ; sa fenêtre de comptage est désormais mise à jour atomiquement, sans remise à zéro des consommations.

Une chaîne signée protège l’intégrité vérifiable du journal. Une ancre extérieure indépendante est nécessaire contre son effacement ou un retour arrière conjoint. Les scores fonctionnels de vigilance ne sont ni une preuve de malware ni des sentiments vécus.

Sources : R2 - Essais VM du 26 octobre 2026 ; R3 - Défense en profondeur et garde locale

06 / RÉFÉRENTIELS DE SÉCURITÉ

Des preuves utiles au programme ISO.

Le kit apporte des mécanismes techniques et un dossier d'exécution. Les correspondances ci-dessous sont une analyse du projet ; elles ne constituent pas une certification ou un audit complet des normes.

Référence	Rôle du référentiel	Contribution du kit
ISO/IEC 27001:2022	Exigences d'un système de management de la sécurité et traitement des risques.	Périmètre, mandats, responsabilité des décisions et preuves d'exécution à intégrer au SMSI du client.
ISO/IEC 27002:2022	Recommandations pour choisir et mettre en œuvre des mesures de sécurité.	Accès bornés, surveillance, journalisation et vérification des interventions. La pertinence dépend du risque.
ISO/IEC 27035-1:2023	Principes et processus de préparation, détection, évaluation, réponse et retour d'expérience.	Événement, enquête, décision, action et résultat conservés dans une chronologie explicable.

CIS Controls v8.1 : repères techniques sélectionnés

Objectif du kit	Familles CIS pertinentes	À compléter chez le client
Inventaire et posture	1, 2 et 4	Périmètre exhaustif, propriétaires, inventaire logiciel et configurations de référence.
Mandats et maintenance	5 et 6	Annuaire, MFA, cycle de vie des accès et revues des droits.
Journal et observation	8 et 13	Couverture réseau, conservation extérieure, alertes et exploitation SOC.
Paquets, reprise, incidents	10, 11 et 17	Politique antivirus, sauvegardes restaurables, exercices et procédure de réponse.

Statut précis. ISO 27001 vise un SMSI sur un périmètre défini. ISO 27002 n'est pas certifiable. Une certification, lorsqu'elle est recherchée, relève d'un organisme externe. Le kit n'est annoncé ni « certifié ISO », ni conforme à l'ensemble des Safeguards CIS.

Sources : R5 - ISO/IEC 27001:2022 ; R6 - ISO/IEC 27002:2022 ; R7 - ISO/IEC 27035-1:2023 ; R8 - ISO : certification et organismes externes ; R9 - CIS Controls v8.1 ; R10 - Liste officielle des 18 contrôles CIS

07 / LECTURE MITRE D3FEND

Nommer les protections. Délimiter leur effet.

D3FEND est un graphe de connaissances des techniques défensives. Il fournit un vocabulaire commun ; il ne garantit ni la priorité ni l'efficacité d'un produit. Version consultée : 1.6.0, le 26 octobre 2026.

Technique de référence	Mécanisme du kit	Ce que le rapprochement ne prouve pas
Process Analysis D3-PA	Attribution aux processus, incarnation, cgroup et inspection de leurs ressources.	Ni analyse de toutes les familles de malware, ni surveillance de chaque processus.
File Access Pattern Analysis D3-FAPA	Corrélation entre opérations sur les fichiers déclarés, identité OS et autorisations.	Ni lecture sémantique de tous les accès, ni intention malveillante déduite d'un seul indice.
File Analysis D3-FA	Sas des paquets .deb soumis, inspection de contenu et recours à ClamAV.	Ni interception générale des téléchargements, ni absence prouvée de porte dérobée.
Application Performance Monitoring D3-APM	Délais des sondes et du témoin, durée des inspections et des appels ; CPU et RAM comme contexte.	Un pic de charge n'identifie pas à lui seul une attaque.

Le classement est descriptif.

Ces correspondances sont proposées par l'équipe SAWM & Basira à partir des fonctions du code. Elles ne constituent ni une validation par MITRE, ni un score de couverture, ni une preuve qu'une technique offensive associée sera automatiquement arrêtée.

Un cadre de test commun avec le client

1. **Définir le cas**
   Quel service et quelle donnée protéger ? Quel comportement doit être autorisé, signalé ou contenu ?
2. **Lier mécanisme et preuve**
   Quelle sonde observe le fait ? Quel reçu démontre l'action ? Quel contrôle confirme la disponibilité et l'intégrité ?
3. **Éprouver les exceptions**
   Maintenance, attribution absente, ticket expiré, perte des capteurs ou du Cloud.

Sources : R11 - MITRE D3FEND : définition et limites ; R12 - D3FEND : File Analysis, D3-FA ; R13 - D3FEND : Process Analysis, D3-PA ; R14 - Matrice D3FEND, version consultée 1.6.0

08 / INTÉGRATION

Du Cloud public à votre VM de test.

Le code public est un kit d'intégration réutilisable. Les moteurs restent privés et sont accessibles avec un compte autorisé, les droits adaptés et les crédits du service.

1. **Créer le périmètre Cloud**
   Depuis basira.sawm.io/espace : créer un espace, une entité serveur et un principal de service ; accorder read/write sur cette entité précise.

2. **Émettre une clé de service limitée**
   Profil Runtime agent + SAWM : events:write, jobs:read, memory:recall, tsst:recall, odvl:rank, sawm:run. Le scope API et le grant d'entité sont deux vérifications distinctes.

3. **Installer le kit et les capteurs**
   Python 3.11+, systemd, cgroup v2 et outils adaptés au noyau. Examiner le plan de préparation, puis installer dans une VM dédiée. eBPF/LSM se construit et se vérifie pour le noyau cible.

4. **Protéger les transports et les clés**
   Coffre local privé, secrets hors Git, clés hôtes SSH vérifiées, dashboard sur loopback avec tunnel authentifié. Le socket de télémétrie exige une isolation ou un transport authentifié.

5. **Observer, puis déléguer**
   Démarrer sans action, raccorder le Cloud, vérifier les preuves. Enrôler la clé publique, définir les cibles/actions et activer uniquement la délégation nécessaire.

Trois modes progressifs

```
python controleur/veille.py --duration 60
python controleur/veille.py --duration 300 --cloud --cloud-per-hour 4
python controleur/veille.py --permanent --cloud --apply --cloud-per-hour 4
```

Ces commandes supposent le transport et les droits déjà configurés. --apply ne remplace pas le manifeste, l'enrôlement de clé ni le mandat de maintenance.

Exploitation. Superviser les processus et surveiller la fraîcheur. Le budget actuel est de quatre tours SAWM par heure, pas quatre requêtes HTTP ni quatre enquêtes complètes. Aucun appel Cloud n'est déclenché par la seule ouverture du dashboard.

Licence. Kit Apache-2.0 ; fichier BPF LSM sous GPL-2.0-only. Services Cloud, marques et droits d'accès restent distincts de cette licence.

Sources : R1 - Kit public et documentation ; R3 - Défense en profondeur et garde locale ; R4 - Démarrage et API publiques

09 / PILOTE CLIENT ET RÉFÉRENCES

Transformer la démonstration en preuve métier.

Le prochain engagement consiste à mesurer cette boucle sur une installation représentative du client, avec un mandat de test, des critères d’acceptation et un responsable identifié.

Avant mise en service	Preuve d’acceptation attendue
Périmètre et droits	Inventaire, services protégés, maintenances, responsables et révocation des accès.
Détection et décision	Scénarios positifs et négatifs, délais, faux positifs, qualité d’attribution et absence d’action hors mandat.
Panne et reprise	Perte du Cloud et des capteurs, redémarrage, épuisement du budget, restauration testée, ancre indépendante.
Charge et exploitation	Capacité par serveur, coûts mesurés, rétention, alertes opérateur, transport authentifié et intégration SOC.

Améliorations prioritaires : rendre la maintenance autonome sans clarification redondante ; reprendre explicitement une enquête après retour humain ; qualifier les grands dossiers, paquets et volumes réseau ; étendre le périmètre des capteurs et l’intégration des identités. Les écarts SSH/NTP et les mesures inconnues du laboratoire restent visibles jusqu’à vérification.

Sources consultées et méthode

Les résultats techniques proviennent de la documentation de campagne et des rapports locaux vérifiés. Les fichiers bruts restent privés ; ce PDF n’inclut ni clé, ni identité de compte, ni adresse du laboratoire. Les références externes ci-dessous sont les sources officielles consultées le 26/10/2026. Les correspondances sont une analyse du projet.

R1 Kit public et documentation

R2 Essais VM du 26 octobre 2026

R3 Défense en profondeur et garde locale

R4 Démarrage et API publiques

R5 ISO/IEC 27001:2022

R6 ISO/IEC 27002:2022

R7 ISO/IEC 27035-1:2023

R8 ISO : certification et organismes externes

R9 CIS Controls v8.1

R10 Liste officielle des 18 contrôles CIS

R11 MITRE D3FEND : définition et limites

R12 D3FEND : File Analysis, D3-FA

R13 D3FEND : Process Analysis, D3-PA

R14 Matrice D3FEND, version consultée 1.6.0

Périmètre : démonstrateur Linux sur données fictives. La couverture de tous les malwares, une résistance à un noyau compromis et la conformité complète d’une organisation ne sont pas établies par ces essais. Le pilote doit éprouver les risques et obligations du client.